

FREE PLAYBOOK

AI Ops Security Playbook

Field-tested strategies to keep operations secure without slowing innovation

By Riccardo Bozzato — Operations & Delivery Consultant | PMP®

Why this exists. After working with a dozen growing digital companies, I kept seeing the same pattern: security treated as a gate at the end, slowing everything down. This playbook distills the actual framework I use to align security with operational workflows — so both improve together.

No fluff. No upsells. Just what works in production.

1. The Alignment Framework

The core idea: **treat security as an operations discipline, not a separate gate.** When security practices are embedded in the delivery pipeline, they stop being a bottleneck.

The #1 mistake: *"We'll add security later. Right now we need to ship."*

The fix: shift-left security into CI/CD so it's automatic, not a manual review.

- **Define a compliance baseline** once (OWASP Top 10, internal policies).
- **Automate the checks** against that baseline in every PR.
- **Make "pass" the default path** — engineers get a green check, not a meeting.
- **Review exceptions** centrally, not per-team.

2. Three Automation Plays

These are the highest-leverage automation plays from real engagements:

Play 1 — Automated dependency scanning in CI/CD

Every PR is scanned for vulnerable dependencies automatically (npm audit, Snyk, Dependabot). No manual checklists, no "security review" gates — just a pass/fail that keeps the pipeline moving.

Play 2 — Infrastructure-as-Code compliance checks

Terraform and CloudFormation templates are validated against your compliance baseline before deployment. Catches misconfigurations (open S3 buckets, missing encryption) before they become incidents.

Play 3 — Automated incident response runbooks

When alerts fire, the runbook executes automatically: creates a Slack channel, pages the right person, starts logging, and drafts the initial post-mortem. Mean time to response drops from hours to minutes.

3. Case Study — €500K Portfolio, 40% Faster

At Esse Solutions I managed a **€500K+ digital project portfolio** coordinating distributed teams of 8–12 across B2B eCommerce (Magento, Shopware) and PIM/DAM (Pimcore).

Challenge: Multiple parallel projects, distributed teams, no standardized processes. Status updates took hours, handoffs were messy, security was an afterthought.

What I did: Introduced structured Agile processes with automated CI/CD pipelines, integrated security scanning, and centralized documentation. Not a big bang — consistent, incremental improvements.

Result	Impact
Team productivity	+25%
Time-to-market	–40%
Project completion	+20% faster
Security incidents	Zero during engagement

4. Your First 30 Days

- **Week 1:** Map your current security gates. Identify the top 3 manual bottlenecks.
- **Week 2:** Add dependency scanning to one repository's CI/CD.
- **Week 3:** Write one automated incident runbook for your most common alert.
- **Week 4:** Measure time saved. Repeat on the next repository.

The hidden cost of chaos: 10 min/day per manual report = 40 hours/year. Context switching between tools = 20% productivity loss. Security as afterthought = rework + technical debt. Operational maturity isn't perfection — it's systems that make the right thing the easy thing.

5. When to Bring In Help

If you're hitting a growth wall — team working harder but shipping slower, burnout up, quality down — that's the signal. I help growing digital companies build the operational architecture that turns chaos into predictable execution.

- Free 30-minute consultation to identify your biggest bottleneck.
- Fractional CTO / Head of Operations, from €1,500.

- DevSecOps & AI integration engagements.

Riccardo Bozzato — Operations & Delivery Consultant | PMP®

riccardobozzato.com · riccardobozzato@gmail.com

© 2026 — Shared freely. Please don't resell.